Social Engineering: Phishing Campaign Simulation

Controlled Laboratory Report for GRC Professionals

A controlled phishing-awareness simulation conducted in an isolated local laboratory using GoPhish, test mailboxes and fictional identities. All figures below are the analyst's own lab observations.

1. Candidate Details & Laboratory Setup

Field	Entry
Name	Abigail Silas
Registration no.	C11/26/CGRCE/17260
Assessment date	31 October 2026
Laboratory setup	Kali Linux VM on an isolated host-only network; GoPhish v0.12.1 admin console; MailHog local SMTP capture (localhost:1025); original fictional training landing page served locally at http://127.0.0.1.

2. Scope & Authorisation Statement

This exercise is a controlled phishing simulation conducted entirely within an isolated local laboratory. All recipients are test mailboxes under my own control, populated with fictional identities. The landing page is original fictional security-awareness training content — not a clone of any real or institutional login page. Password capture is disabled; only a dummy form-submission event is recorded as evidence. No real individuals are targeted, and no genuine credentials are collected or stored. Results describe observations from a small simulated sample and are not evidence of any organisation's control effectiveness.

3. Evidence Log

Key events recorded during the controlled run

Time	Action
8:40pm	Confirmed VM on isolated host-only network adapter
8:57pm	Started MailHog local SMTP capture service
9:23pm (29/10/2026)	Launched GoPhish admin console
08:05AM	Campaign "Lab Simulation 01" launched (3 emails sent)
~08:24AM	Recipient interactions completed (3 opened, 2 clicked, 1 submitted)
8:30AM	Campaign marked Completed; evidence captured

4. Metric Definitions & Denominators

Denominators were fixed before launch. Raw counts are reported alongside every percentage because of the small sample.

Metric	Formula	Denominator
Delivery rate	Delivered ÷ Emails sent	Emails sent
Open rate	Opened ÷ Delivered	Delivered
Click rate	Clicked ÷ Delivered	Delivered
Submission rate	Submitted ÷ Clicked	Clicked

Click-rate base: Delivered (the common awareness-reporting choice), applied consistently throughout.

5. Phishing Risk Assessment

Funnel stage	Count	Denominator	Rate	Risk interpretation	Limitation	Recommended control
Emails sent	3	—	—	Baseline volume dispatched	Lab volume only	N/A
Delivered	3	Sent	100%	All test emails reached the capture inbox	SMTP sandbox, not production filters	Validate SPF/DKIM/DMARC in production
Opened	3	Delivered	100%	Every recipient engaged with the email	Opens self-generated in lab; pixel under-counts blocked images	Reinforce sender-verification habits
Clicked	2	Delivered	66.7%	Two of three followed the lure link	Single pretext, tiny sample	Awareness training; link-hover guidance
Submitted	1	Clicked	50%	One would-be credential exposure (dummy data only)	Capture disabled; no real credentials at risk	MFA; report-phish button; input warnings

Overall observation: Of 3 emails delivered to the lab capture inbox, all 3 were opened (100%), 2 links were clicked (66.7% of delivered) and 1 reached the dummy submission form (50% of clicks; 33% of delivered). The counts are small, so every event shifts the percentages substantially.

6. Executive Summary & Recommendations

Scope. A controlled phishing-awareness simulation was run in an isolated local laboratory against three test mailboxes under the analyst's own control, using fictional identities and original training content. No real users, systems or credentials were involved.

Method. A single phishing pretext was dispatched via GoPhish through a local MailHog SMTP capture service. Recipient interactions — delivery, opening, link-clicking and dummy-form submission — were recorded from the GoPhish dashboard. Password capture was disabled throughout; a form-submission event served as evidence of susceptibility.

Key findings. Of 3 emails delivered to the test inbox, all 3 were opened, 2 of 3 recipients clicked the lure link (66.7% of delivered), and 1 submitted a dummy staff ID (50% of clicks; 33% of delivered). Engagement was high through the open and click stages, with the sharpest drop-off at the submission step.

Business implications. Within the limits of a small simulated sample, the exercise illustrates how a plausible lure can move a recipient through the open → click → submit funnel. It demonstrates the value of layered controls rather than proving any specific weakness in a real organisation's defences.

Prioritised recommendations.

1. Enforce MFA on all externally reachable accounts — limits the impact of any credential that is phished.
2. Deliver targeted awareness training and repeat simulations periodically to build and measure a reporting culture.
3. Deploy a one-click "report phishing" button so suspected lures reach security quickly.
4. Harden email authentication (SPF, DKIM, DMARC) and inbound filtering in production.
5. Re-run with larger, varied samples before drawing any conclusions about organisational susceptibility.

7. Limitations

These constraints bound every figure in this report and should be read before any result is interpreted.

- Very small sample. With only three test mailboxes, each event shifts the percentages dramatically. Rates are reported with raw counts for this reason and should not be generalised.
- Single pretext. Only one lure was tested; susceptibility varies widely by theme, timing and sender.
- Self-generated, non-naive interactions. Opens, clicks and the submission were performed by the analyst against controlled test identities, not an unaware user population.
- Sandboxed email path. Delivery ran through MailHog, bypassing the spam filters, link rewriting and warning banners a production mail system would apply.
- Instrumentation effects. Open tracking relies on a pixel that blocked-image clients under-count, and click tracking cannot confirm intent behind a click.
- No credential capture. Password capture was disabled by design; the submission metric reflects a dummy-form event, not actual credential exposure.

Conclusion on scope: this simulation demonstrates the mechanics of a phishing funnel and the analyst's ability to run and measure a controlled campaign. It does not, and is not intended to, prove that any organisation's training or email controls are effective or ineffective.

8. Campaign Evidence

Screenshots from the controlled run. No passwords, API keys or SMTP secrets are shown (SMTP authentication was not used and the admin password line is not captured).



Figure 1 — GoPhish v0.12.1 downloaded, extracted and launched on Kali Linux.

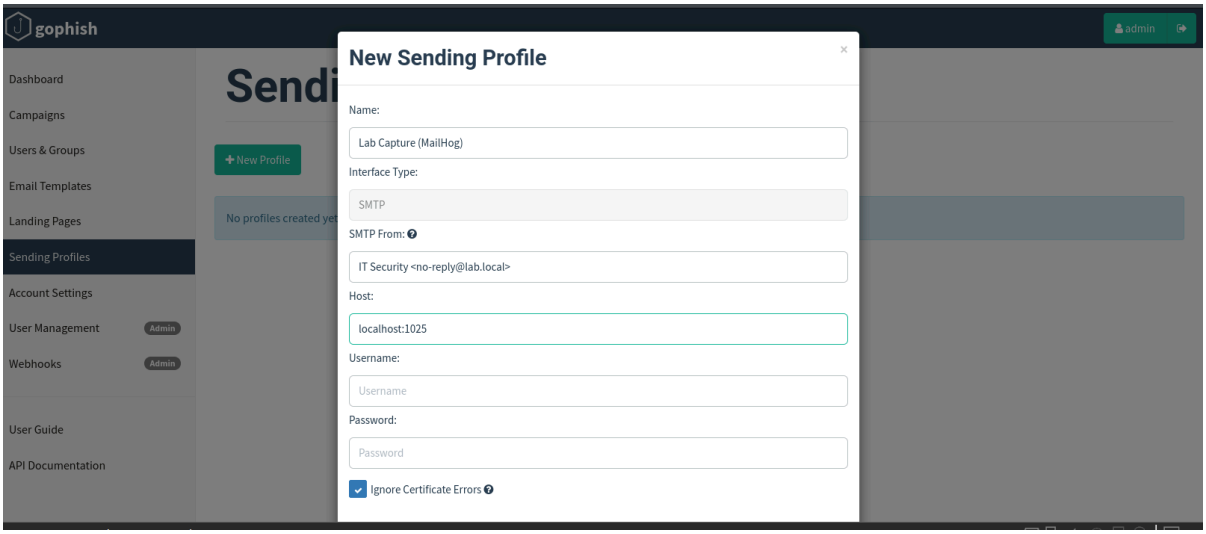


Figure 2 — Sending profile pointed at the local MailHog capture service (localhost:1025); no credentials used.

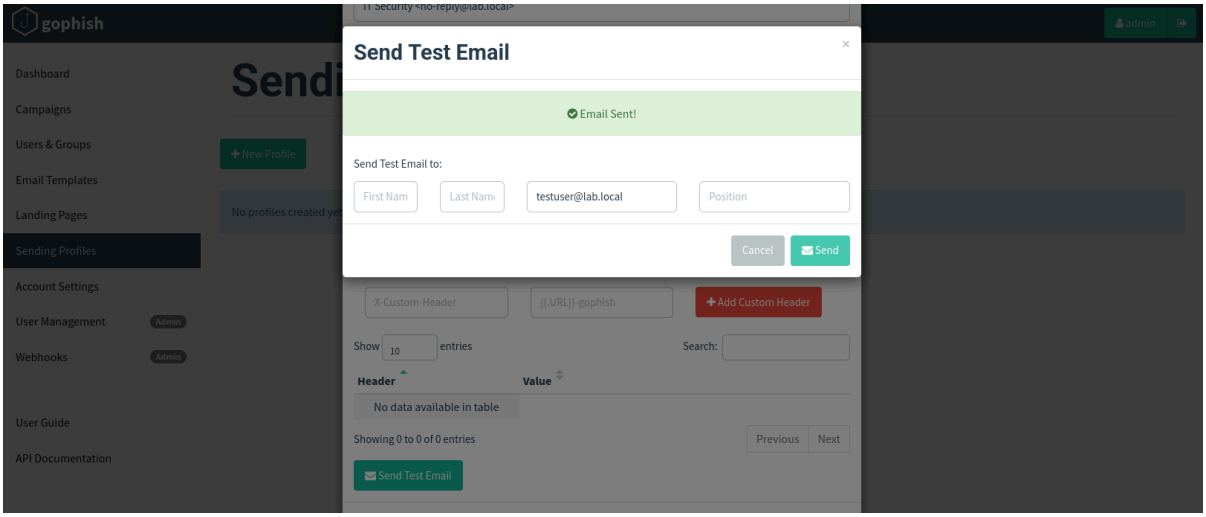


Figure 3 — Test-email confirmation, verifying the capture pipeline before launch.

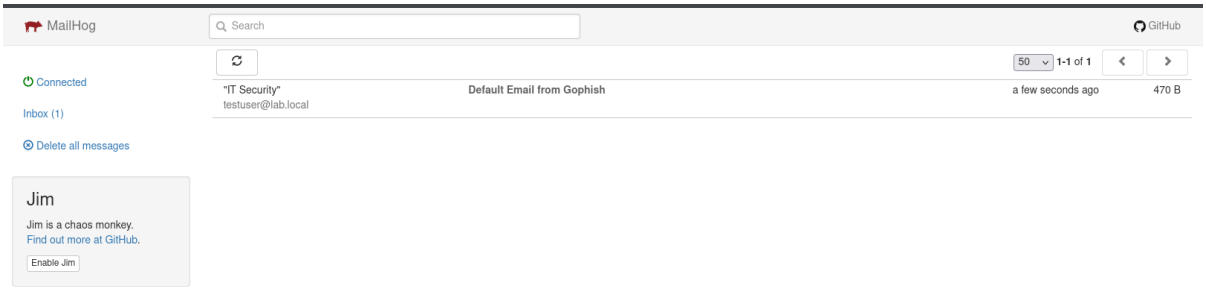


Figure 4 — MailHog capture inbox receiving the test message — no mail leaves the lab.

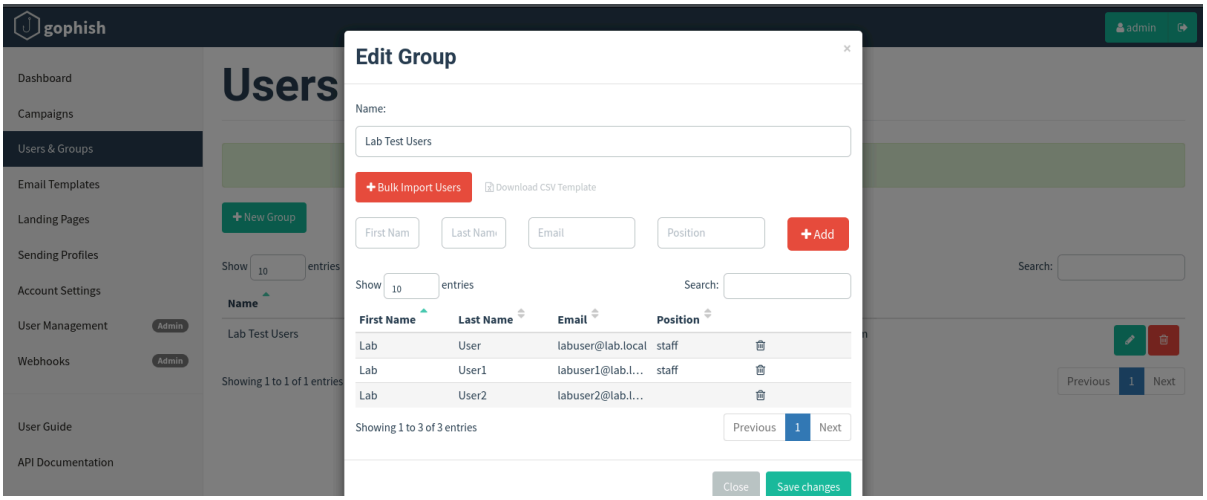


Figure 5 — Target group of three fictional test identities (@lab.local).

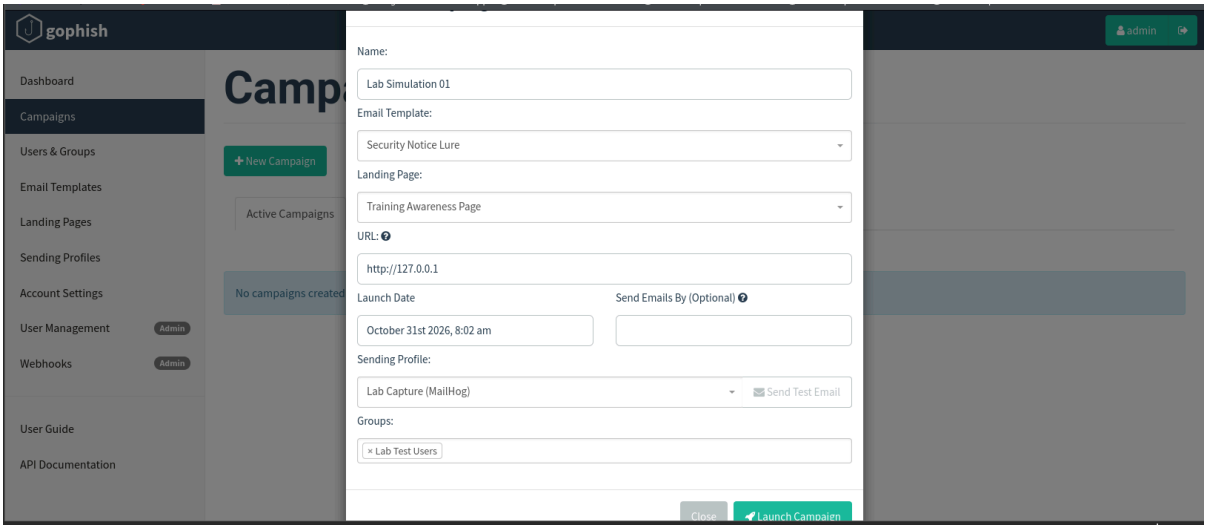


Figure 6 — Campaign configuration: template, fictional landing page and lab URL (http://127.0.0.1).

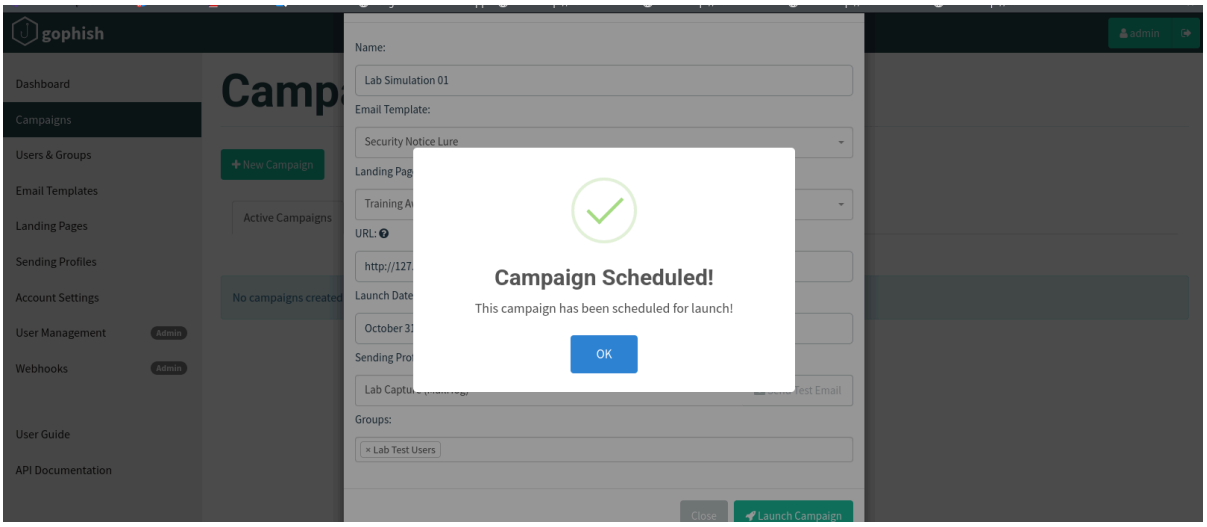


Figure 7 — Campaign launch confirmation.

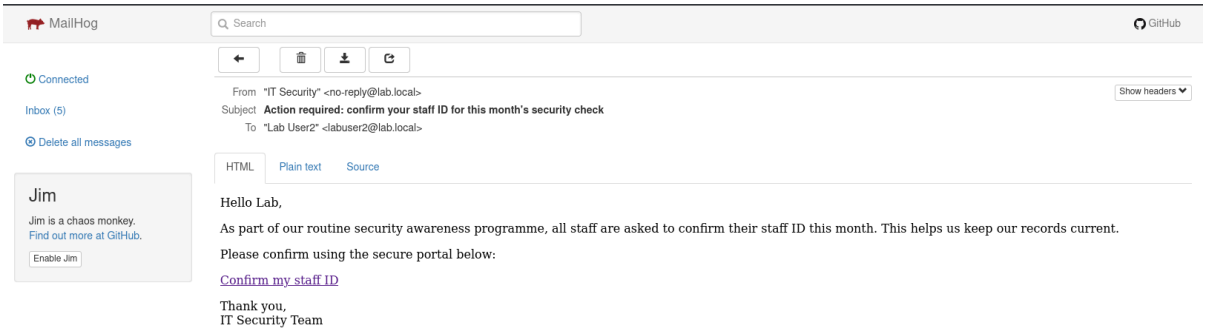


Figure 8 — The simulated awareness email as received in the capture inbox.

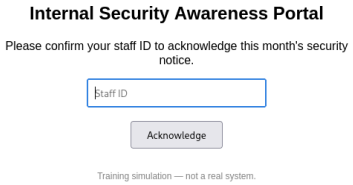


Figure 9 — Fictional training landing page: a single Staff ID field, no password capture.

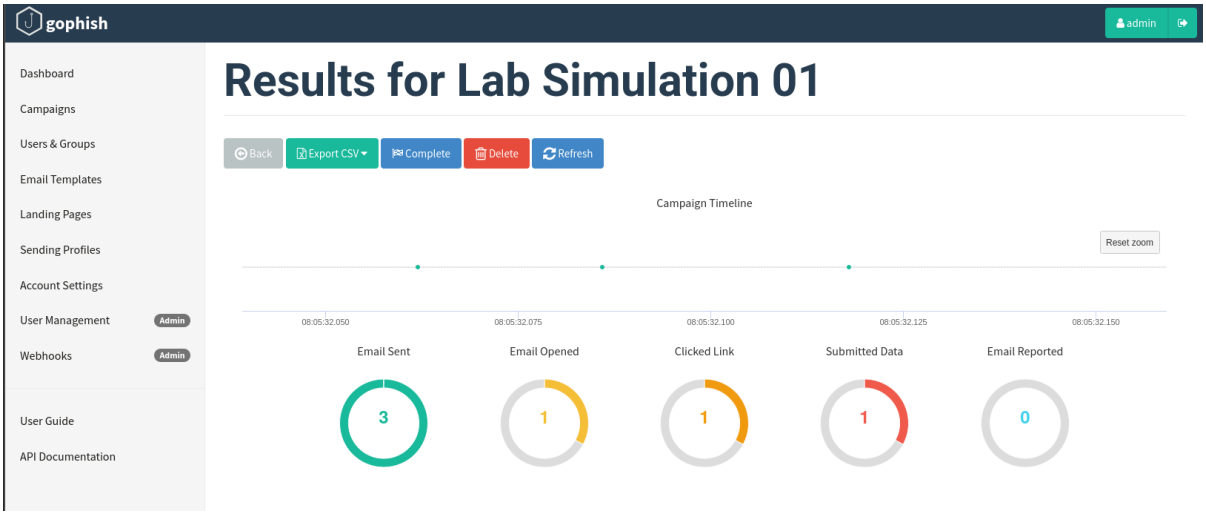


Figure 10 — Dashboard mid-run (1 opened / 1 clicked / 1 submitted).

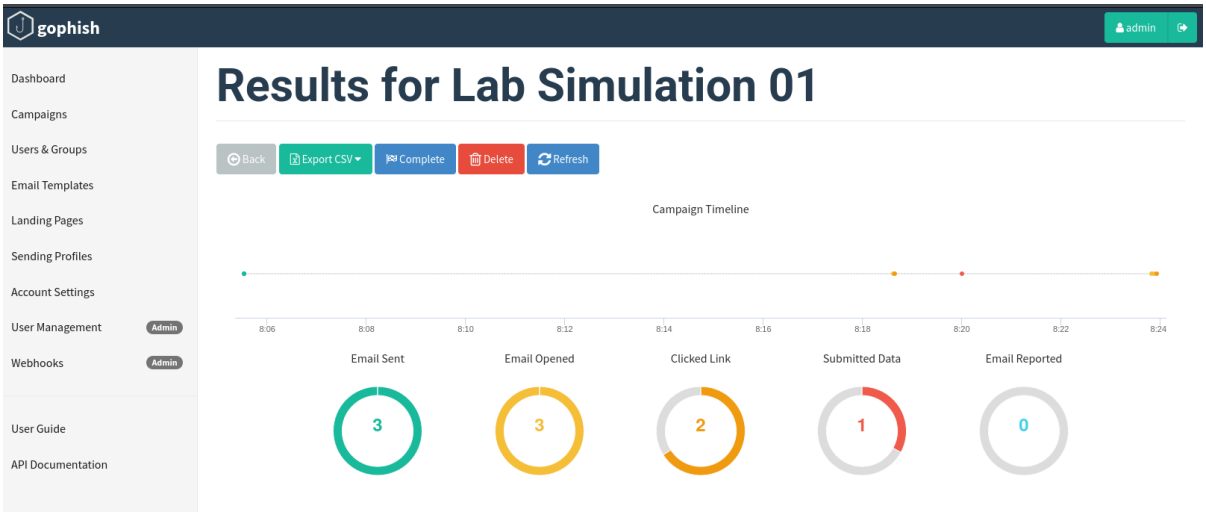


Figure 11 — Final results: 3 sent, 3 opened, 2 clicked, 1 submitted.

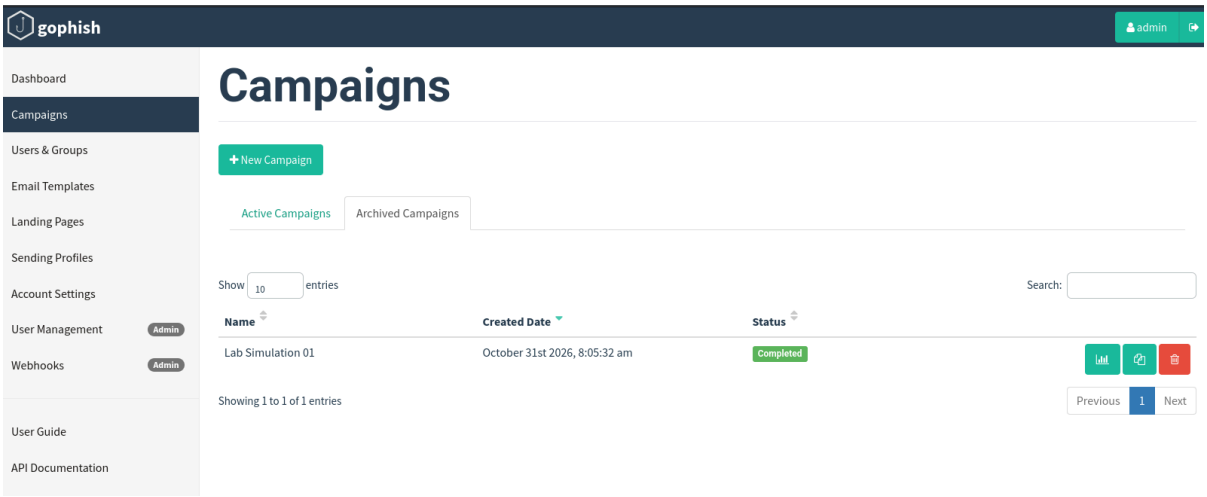


Figure 12 — Campaign marked Completed; data frozen for reporting.